



CLOUD COMPLIANCE BEST PRACTICES CHEAT SHEET

Stay audit ready every day, not only audit week

The do's and don'ts for six continuous compliance practices, with the AccuKnox setup page for each gap you find.

Compliance now costs **weeks** of every year

Firms face more audits each year, and regulators keep issuing large fines. A team that rebuilds evidence by hand for each audit pays for the same work again and again.

€1.2B

in GDPR fines issued by European supervisory authorities in 2025.

DLA Piper, [GDPR Fines and Data Breach Survey](#), January 2026

74%

of large enterprises manage four or more audits a year. 97% of all firms run at least two.

A-LIGN, [2026 Compliance Benchmark Report](#)

11

working weeks a year go to compliance tasks, one week more than the year before.

Vanta, [State of Trust Report 2024](#)

Breach notifications to European regulators rose 22% in a year, from 363 to 443 a day.

DLA Piper, [GDPR Fines and Data Breach Survey](#), January 2026

Point in time audits miss what **changes daily**

Cloud resources change on every deploy. An audit checks one day, so four habits leave the gaps in place.



Each framework is its own project

97% of firms run at least two audits a year. When CIS, SOC 2 and PCI DSS each get a separate spreadsheet, the team tests and documents one control three times.



Evidence is gathered by hand

A screenshot taken in audit week proves the state of one day. Leaders in the Vanta survey say automation would save 3 to 5 hours each week.



Scope stops at the cloud account

CIS publishes separate benchmarks for Kubernetes and for each operating system. A cloud account scan reads the provider API and checks neither one.



Failed controls have no owner

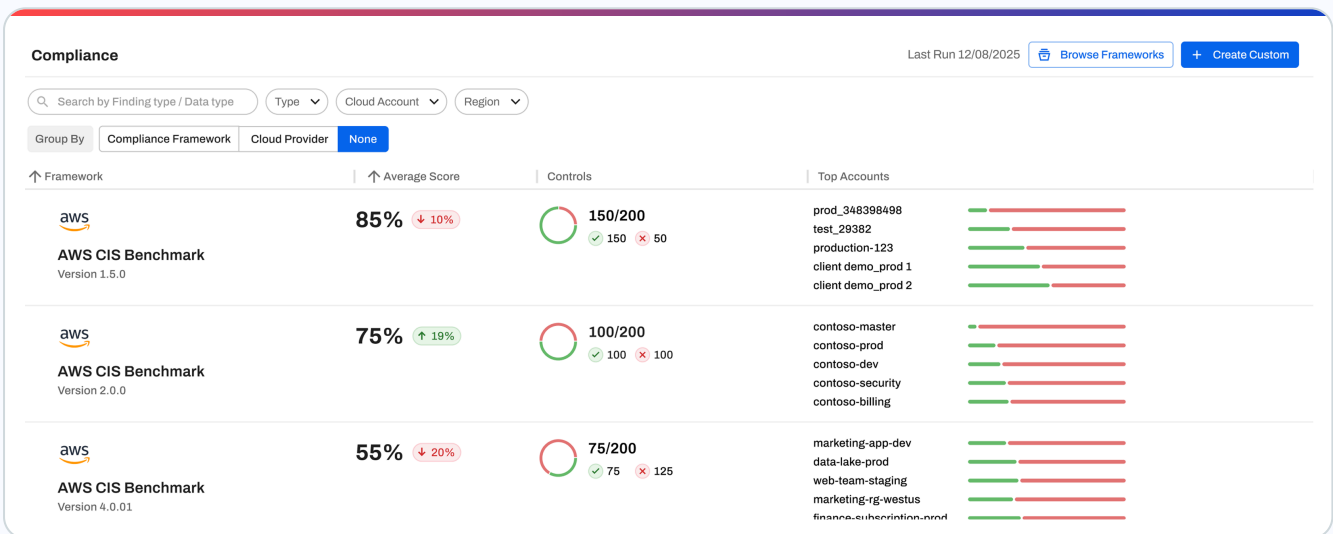
A failed check with no ticket and no due date stays failed. The next change to the account adds new drift on top of it.

Sources: A-LIGN, [2026 Compliance Benchmark Report](#). Vanta, [State of Trust Report 2024](#).

Start here

Six practices keep you audit ready

Each practice removes one manual step from audit season. Run all six, and every scan adds to the evidence between audits.

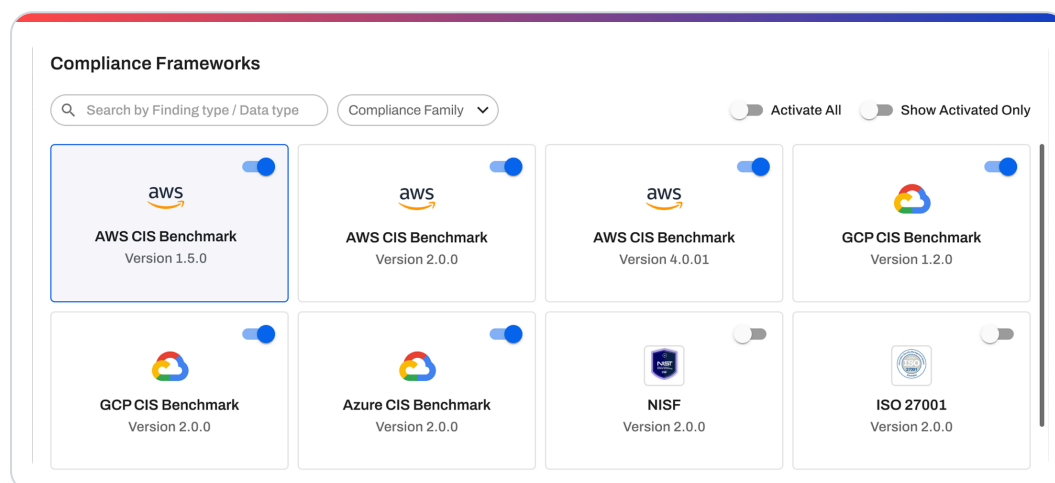


Compliance view with a score for each framework. help.accuknox.com/use-cases/compliance/

- | | | | | | |
|----|---|----|----|---|----|
| 01 | Map controls once
One check feeds every framework | 05 | 04 | Schedule audit ready reports
Daily, weekly or monthly, by email | 08 |
| 02 | Collect evidence continuously
Every scan adds to the record | 06 | 05 | Assign owners and tickets
Every failed control gets a ticket | 09 |
| 03 | Cover workloads
Kubernetes and VMs, not only accounts | 07 | 06 | Track drift
Catch the change before the auditor | 10 |

Map each control once, report it to **every framework**

AccuKnox ships more than 1,000 checks, and each check maps to the sub controls of one or more compliance programs.



Compliance Frameworks catalog. help.accuknox.com/use-cases/compliance/

DO

- Open Browse Frameworks and turn on each framework you report against, such as SOC 2, ISO 27001, PCI DSS or HIPAA.
- Fix a failed check once. The next scan updates the result in every framework that maps to it.
- Add internal policy with Create Custom, so company controls sit beside the standards.
- Run one Cloud Compliance report for one account across several frameworks, such as HIPAA and APRA 234.

DON'T

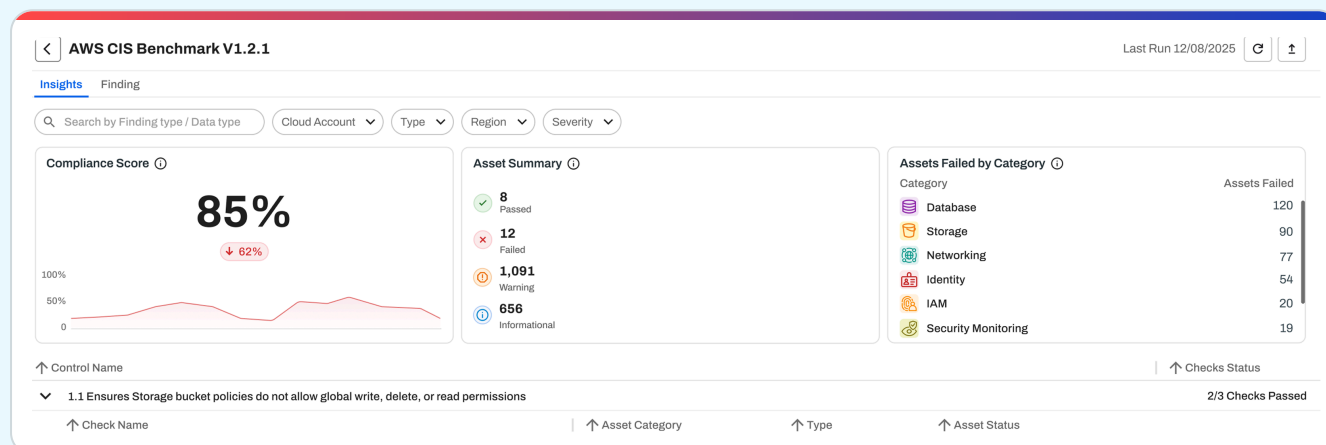
- Don't keep a separate control spreadsheet for each framework.
- Don't open one ticket per framework for the same failed check.
- Don't assume every framework covers every cloud. The support matrix lists AWS Well Architected for AWS only.

HOW ACCUKNOX CLOSSES THE GAP

More than 30 frameworks come mapped to AWS, Azure and GCP checks, so one result feeds every program that uses it. [Read the compliance guide](#)

Collect evidence on every scan, not in audit week

Each scan scores every control and keeps the history, so last quarter's record exists before the auditor asks.



Benchmark insights with score trend and checks per control. help.accuknox.com/use-cases/compliance/

DO

- Onboard every cloud account, so scans run on a schedule with no person starting them.
- Read the score per sub control. It equals passed checks over passed, failed, warning and not available checks.
- Filter the Detailed View by account, region and severity to give the auditor the exact scope.
- Let the lifecycle close findings. A finding absent from two scans in a row moves to Fixed.

DON'T

- Don't collect screenshots the week before the audit.
- Don't treat Warning or Not available as a pass. Both count against the score.
- Don't ignore a finding to lift the score. Mark it Accepted Risk or Exception Requested, so the decision stays on record.

HOW ACCUKNOX CLOSES THE GAP

The findings lifecycle sets each status from scan results and keeps a history of actions on every finding. [Read the findings lifecycle](#)

Cover the workloads, not only the **cloud account**

Kubernetes clusters and VMs carry their own CIS and STIG controls, and a cloud account scan does not read them.

The screenshot shows a finding titled "1.1.2: Ensure that the API server pod specification file ownership is set to root:root (Automated)" with a severity of "High". The finding is 78 days old, has an SLA of 45 days, and 0 tickets created. The description states: "Ensure that the API server pod specification file ownership is set to root:root (Automated)". The finding is associated with the resource "k8s_CIS_Cluster | DO-demo-cluster". It is marked as "Failing since" about 4 months ago (22/07/2024) and "Last detected" about 1 month ago (08/10/2024). The status is "Active".

CIS Kubernetes Benchmark finding with SLA and failing since date. help.accuknox.com/how-to/cis-benchmarking/

DO

- Turn on the Kubernetes CIS Benchmarking job in Settings, Manage Clusters, and set a scan schedule.
- Install the VM Scanner with Knoxctl for CIS or DISA STIG profiles on Ubuntu 22.04 and 24.04.
- Filter Issues, Findings by CIS k8s Benchmarking or STIG to review workload results.
- Review manual controls yourself. 541 of the 1020 VM controls need human judgement.

DON'T

- Don't read a skipped control as a pass. The scanner reports manual controls as skipped.
- Don't expect CIS Kubernetes results on every distribution. The docs list managed GKE clusters today.
- Don't onboard a cluster without a label. The CIS job uses the label to identify the cluster.

HOW ACCUKNOX CLOSES THE GAP

One platform covers cloud, workload and AI compliance, with agentless scans for public cloud and agents for private and air gapped sites. [Set up VM benchmarking](#)

Schedule the report before the auditor asks

Scheduled reports run daily, weekly or monthly and go by email to every recipient you name.

Reports [Browse Report Templates](#)

Cloud Findings Report
CSPM

Create

Cloud Compliance Report
CSPM

Create

Vulnerability Report
CWPP

Create

ASPM Report
ASPM

Create

Metabase Report
Custom

Create

Search by Report Name Report Category Frequency

☐	Report Name	Report Category	Frequency	Duration	Created	Last Generated Date	Email Recipients	Action
☐	Cloud Findings Report - Every Week	CSPM	OnDemand	NA	June 12, 2025	June 12, 2025	1	Download Generate
☐	Compliance Findings Report - Biweekly report	CSPM	Scheduled	Last 14 days	May 11, 2025	June 12, 2025	4	Download
☐	Vulnerability Report	CWPP	OnDemand	NA	Apr 4, 2025	June 12, 2025	5	Download Generate
☐	Shift left - ASPM Report	Custom	Scheduled	Last 30 days	Mar 18, 2025	June 12, 2025	12	Download
☐	Metabase Report	Custom	Scheduled	Last 2 days	Mar 9, 2025	June 12, 2025	8	Download

Reports with scheduled and on demand compliance reports. help.accuknox.com/how-to/custom-reports/

DO

- Create a Cloud Compliance Report from Browse Report Templates and set it to Scheduled.
- Match the date range to the audit period, such as the last 14 or 30 days.
- Add the GRC lead and each control owner as email recipients.
- Run one framework across many accounts when the auditor scopes by standard.

DON'T

- Don't build the audit pack by hand from CSV exports.
- Don't wait for audit week to ask for a custom template. AccuKnox Support configures custom templates first.
- Don't send an export with no date range. The auditor needs the period it covers.

HOW ACCUKNOX CLOSES THE GAP

Scheduled CSPM and ASPM reports are versioned and status tracked, which gives SOC 2 and ISO 27001 audits consistent evidence. [Configure scheduled reports](#)

Give every failed control an owner and a ticket

A finding with no owner stays open. Route each failed check to the team that can fix it.

aws-logs-788471067825 Critical

Create Ticket Comment Askada

Overview

Tickets

Comments

Check: PostgreSQL Log Checkpoints Enabled

Check Result: Failed

Asset Category: Account

Account: [Redacted]

Severity: Critical

Location: us-east-1

Description: Ensures Private Google Access is enabled for all Subnets.

Compliance Frameworks: CIS, AICPA SOC, PCI DSS

Failed check with Create Ticket and its mapped frameworks, account redacted. help.accuknox.com/how-to/findings-lifecycle/

DO

- Connect Jira, ServiceNow or another ticketing tool, then open tickets from the finding.
- Write a Rules Engine rule that opens a ticket for every new critical compliance finding.
- Set an expiration on each rule, and review the rule before it lapses.
- Use In Progress, Waiting for 3rd Party and Accepted Risk, so the status tells the auditor what happened.

DON'T

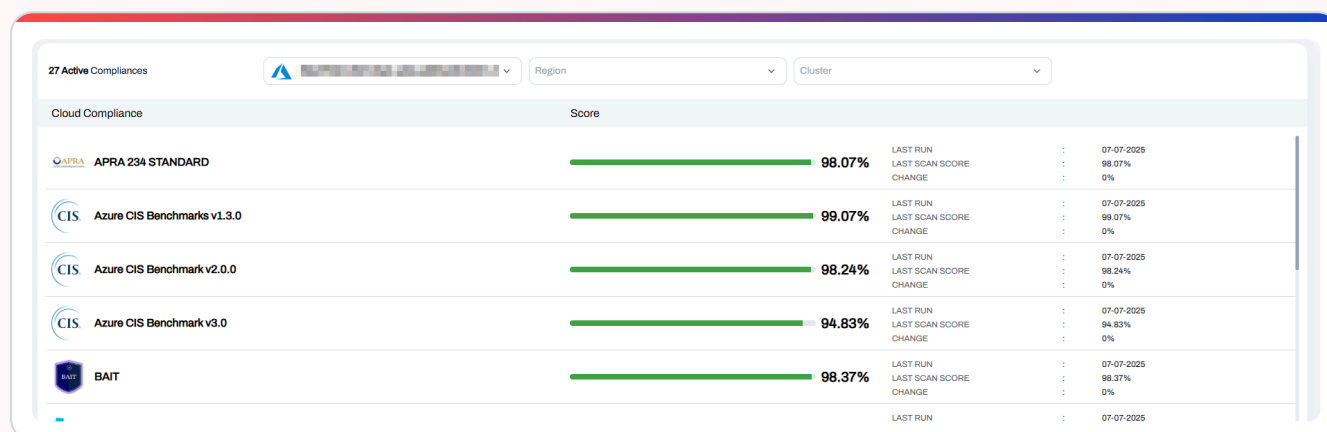
- Don't let critical findings sit unticketed. The summary report counts them.
- Don't mark Accepted Risk without a comment that names who approved it and why.
- Don't close a ticket before the next scan confirms the fix.

HOW ACCUKNOX CLOSES THE GAP

The Rules Engine applies one rule to every matching finding, so a new failure reaches its owner with no manual triage. [Automate ticket creation](#)

Track drift between audits, not after them

Compare each scan with the last one, and alert when a critical asset changes.



Compliance summary with last scan score and change per framework. help.accuknox.com/use-cases/compliance/

DO

- Check the change value on the compliance summary after each scan.
- Group critical assets and apply a baseline conformance check on a schedule.
- Set Monitors on assets such as S3 buckets and bastion hosts to alert on any configuration change.
- Read the weekly trend of new and critical findings in the summary report.

DON'T

- Don't wait for the annual audit to learn that a score dropped.
- Don't fix drift only in the console. Fix the IaC template too, or the next deploy brings the drift back.
- Don't put a Monitor on every asset. Start with the assets in audit scope.

HOW ACCUKNOX CLOSSES THE GAP

AccuKnox tracks compliance configuration changes in one view, and alerts when a monitored asset drifts from its baseline. [Set up drift detection](#)

Find your gap, then take the first step

Read each row. Where the statement is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Each framework lives in its own spreadsheet	Compliance framework mapping	Turn on your frameworks in Browse Frameworks
Evidence is collected by hand before each audit	Scheduled scans and findings history	Onboard every cloud account with a scan schedule
Kubernetes and VMs sit outside compliance scope	CIS Kubernetes job and VM Scanner	Enable the CIS Benchmarking job on one cluster
Reports are built by hand for each auditor	Scheduled Cloud Compliance Report	Schedule a weekly report to the GRC lead
Failed controls have no owner	Rules Engine ticketing	Create a rule for new critical findings
Nobody sees a score drop until the audit	Drift detection and Monitors	Set a Monitor on one critical storage bucket

See your frameworks scored on your own cloud

Book a demo to see your frameworks mapped, scored and reported from one AccuKnox console.

[Book a demo](#)

[Read the compliance docs](#)

33+

global compliance frameworks supported

1,000+

out of the box compliance checks in CSPM

2026

featured in the KuppingerCole CNAPP Leadership Compass

Sources: accuknox.com/compliance, help.accuknox.com/use-cases/compliance, accuknox.com/analyst-recognition